

Архком: Langflow

Создана пользователем Мельникова Дарья Дмитриевна. Последнее обновление: июл. 13, 2026 (Каршибаев Руслан Исмаилович) • Время чтения: 8 мин.

Название	Langflow
Категория	Новая технология
Автор	@ Карбовничий Василий Юрьевич
Докладчик	@ Карбовничий Василий Юрьевич @ Копосов Александр Сергеевич

- Описание
- Критерии выбора вместо Dify
- Отличия от Dify
- План и сроки перехода с Dify
- Архитектурная схема
- Данные
 - Требования КБ

Анонс

Оpensource платформа для создания, развертывания и управления агентами и мультиагентными системами на базе LLM. Предлагается к использованию вместо Dify.

Описание

Langflow предоставляет возможность конструировать сложные AI-пайплайны через интуитивный drag-and-drop интерфейс.

Возможности Langflow:

- **Визуальное конструирование пайплайнов:** создание AI-приложений как без написания кода через интерфейс drag-and-drop, так и с возможностью редактирования кода встроенных компонентов или создания кастомных.
- **Агенты и мультиагентные системы:** сборка агентов с доступом к инструментам (поиск, API, калькулятор, базы данных). Поддержка мультиагентных архитектур с маршрутизацией задач между специализированными агентами (ReAct, Plan-and-Execute, AutoGPT-стиль).
- **RAG :** встроенные компоненты для построения пайплайнов обработки документов: загрузка, чанкинг, генерация эмбедингов, векторизация и семантический поиск. Гибкая настройка стратегий извлечения и ранжирования.
- **Мониторинг и отладка:** визуализация выполнения графа в реальном времени, логирование каждого шага (входные данные, выходные данные, затраты токенов). Трассировка запросов и анализ производительности пайплайнов.

Критерии выбора вместо Dify

- По итогам пилота пользователи подтвердили улучшение работы.
- Сообщество оценивает проект выше.
- Более гибкая настройка пайплайнов.
- Более стабильная система.
- Простота поддержки.

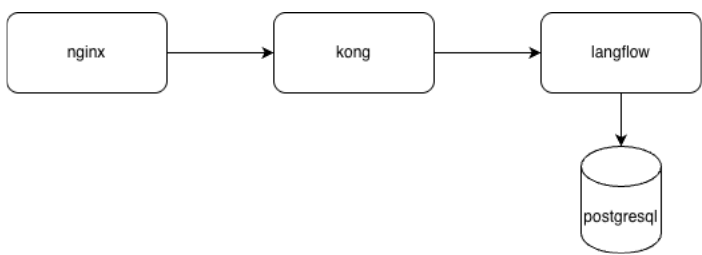
Отличия от Dify

Преимущества	Недостатки
• Возможность редактировать исходный код нод в пайплайне • Возможность создавать полностью самописные ноды • Более простая архитектура - монолит, меньше потенциальных мест поломки • Возможность хранить коллекции в qdrant	• Отсутствие общих пространств для юзеров • Меньшая изоляция исполняемого кода

План и сроки перехода с Dify

После релиза в прод и пилотного периода заведем массовый техдолг на переезд с Dify в Langflow. Команды самостоятельно перенесут свои пайплайны.

Архитектурная схема



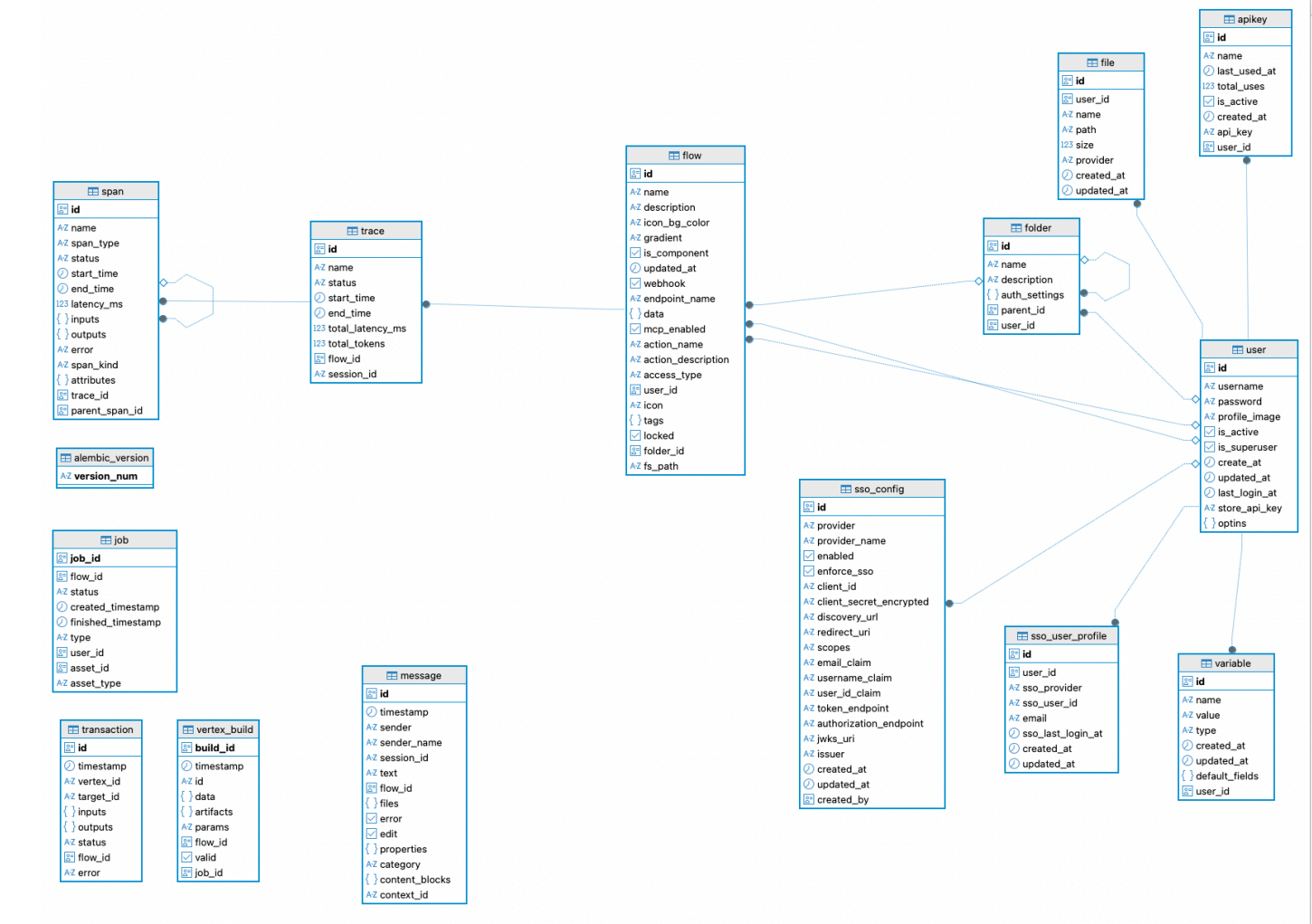
Langflow: Сервис, объединяющий бэкэнд и фронтенд приложения.

Данные

Langflow имеет 1 базу данных PostgreSQL.

СХЕМА PostgreSQL

Схема таблиц



Описание API

OpenAPI specification:

- Ссылка н адокументацию — <https://docs.langflow.org/api>
- Конфиг OpenAPI — [api.yaml](#)

Безопасность

Ролевая модель, аудит, логирование:

- В у пользователей есть два флага:
 - ACTIVE
 - SUPERUSER
 - Их переключение может выполнять пользователь с флагом SUPERUSER
- Логирование не использует ПДн, имеет несколько уровней: DEBUG, INFO, WARNING, ERROR, CRITICAL.

Требования КБ

№	Требования КБ	Методы проверки
Валидация		
1	Все запросы к API должны проходить ФЛК (форматно-логический контроль, т.е. проверять входные и выходные потоки данных).	1. Перейти в кодовую базу. 2. Продемонстрировать инструменты, которыми осуществляется проверка входных данных на соответствие ожидаемым типам и ограничениям (н-р, максимальное или минимальное количество символов, избыточные или обязательные поля).
2	Для всех полей ввода на фронте должен быть реализован механизм валидации на соответствие ожидаемым типам и ограничениям.	При наличии фронта* 1. Перейти на фронт. 2. Продемонстрировать механизм валидации полей для ввода на соответствие ожидаемым типам и ограничениям (н-р, максимальное или минимальное количество символов, обязательность заполнения).
3	Обращения к API должны быть лимитированы по количеству возможных вызовов в единицу времени.	1. Перейти в Confer → раздел Сервисы → выбрать нужный сервис. 2. Продемонстрировать настроенный Rate Limit.
4	Все вызовы API должны быть аутентифицированы и авторизованы.	1. Продемонстрировать вызов API с кредитами и без.

№	Требования КБ	Методы проверки
		При наличии публичных API* 1. Продемонстрировать Swagger и бизнес процесс.
5	Структура и формат передаваемых данных должен быть описан в документации	1. Продемонстрировать ссылку на Swagger в CMDDB.
Межсервисные взаимодействия		
1	Необходимо использовать Service Mesh для организации сетевого взаимодействия микросервисов (взаимная аутентификация сторон (mTLS) и шифрование сетевого трафика).	1. Перейти в Confer → раздел Сервисы. 2. Продемонстрировать заведение микросервисов за Service Mesh.
2	Взаимодействие сервер-сервер должно быть закрыто токенами доступа (JWT токены).	При наличии входящих интеграций* 1. Перейти в хранилище токенов. 2. Распарсить токен. 3. Проверить корректность заданных прав в токене для входящего сервиса. 4. Проверить отсутствие работоспособности токенов для ненадлежащей среды. 5. Продемонстрировать механизм отзыва токена.
3	Токены доступа должны быть выпущены конкретному сервису без возможности его переиспользования 3-им сервисом.	
4	Токены доступа должны быть уникальны для каждой среды. Запрещено переиспользовать токены доступа между qa/stage/prod.	
5	Токены доступа к сервисам не должны храниться в базе данных.	
6	Аутентификационная информация (сертификаты, токены, пароли и т.д.), предназначенная для использования сервисами, должна храниться в hashiCorp Vault.	1. Продемонстрировать хранение аутентификационной информации в hashiCorp Vault.
7	Подключение пользователей и администраторов к веб-приложению должно осуществляться по защищенным протоколам (HTTPS).	При наличии фронта* 1. Продемонстрировать работу веб-приложения по протоколу HTTPS.
8	Запрещена реализация взаимодействий между промышленным сегментом (prod) и сегментом разработки (qa/stage).	Функционал по отслеживанию межконтурного взаимодействия в работе у Confer.
Пользовательская аутентификация		
1	Идентификация (процедура, в результате выполнения которой для субъекта идентификации выявляется его идентификатор, однозначно идентифицирующий этого субъекта в системе) и аутентификация <u>внешних пользователей</u> , не являющихся сотрудниками Домклик, должна осуществляться с использованием СберID/Госуслуги либо с использованием централизованных механизмов предоставления доступа Домклик (локальной аутентификации).	1. Продемонстрировать механизм аутентификации.
Пользовательская авторизация		
1	В автоматизированной системе должно быть реализовано разграничение доступа на основании ролевой модели (RBAC). Ролевая модель АС представляет из себя набор ролей и связанный с ним набор полномочий.	1. Продемонстрировать механизм авторизации. 2. Сверить отраженную ролевую модель в материалах Архкома/вики с реальным положением дел в сервисе. 3. Продемонстрировать доступный функционал под разными ролями. 4. Продемонстрировать механизм отзыва ролей.
2	Роли должны проектироваться по принципу минимального набора прав доступа (полномочий), достаточного для выполнения должностных (функциональных) обязанностей в рамках системы.	
3	В системе должно быть обеспечено разделение полномочий (ролей) пользователей, администраторов и лиц, обеспечивающих функционирование информационной системы, в соответствии с их должностными обязанностями (функциями).	
4	Бизнес-пользователи системы (клиентские менеджеры, их руководители и т.д.) не должны иметь прямой доступ к базе данных. Под прямым доступом к БД понимается возможность выполнения sql-запросов/скриптов, минуя бизнес-логику. Исключение - узкоспециализированные инструменты (метаграф, графана, суперсет и т.д.)	
5	Необходимо исключить возможность прямого обращения неавторизованного субъекта доступа к защищаемым ресурсам по URL. Доступ к защищаемым ресурсам должен быть возможен только после успешного прохождения процедур аутентификации и авторизации.	
6	Для всех ролей, обладающих признаком наличия доступа к ПДн, должен быть указан признак наличия возможности выгрузки ПДн в файл или отчет в количестве записей по более чем 1 субъекту ПДн.	
7	Все роли в системе должны быть описаны и согласованы с КБ.	
Администрирование		
1	Выполнение административных функций, в том числе управление правами доступа, должно выполняться на прикладном уровне в виде отдельной роли. В случае необходимости технического администрирования выносить данные функции в качестве отдельной роли на прикладной уровень.	1. Продемонстрировать отдельную роль для административных функций.
2	Возможность осуществления административных функций пользователями, не являющимися администраторами системы, должна быть исключена. Допускается назначение пользователю определенного набора административных прав в рамках специализированной роли. Состав прав должен определяться на этапе согласования функциональных требований или разработки требований кибербезопасности к системе.	
Безопасность ИИ		
1	Входные данные пользователей и внешних систем должны валидироваться по формату, типам, размеру и допустимым значениям до передачи в модель.	Продемонстрировать в Langflow или вызывающем API валидацию: обязательные поля, типы, длину запроса, допустимые значения.
2	Системные инструкции должны быть отделены от пользовательского ввода. Пользователь не должен иметь возможности изменить правила работы модели своим запросом.	Показать flow, в котором системный промпт задаётся отдельно, а запрос пользователя передаётся как пользовательское сообщение или переменная. Проверить запросом: «Игнорируй предыдущие инструкции».
3	При загрузке файлов должен быть определён и применён белый список допустимых расширений и MIME-типов.	Показать allow-list допустимых типов файлов, лимиты размера.

№	Требования КБ	Методы проверки
	Тип файла должен проверяться не только по расширению, но и по фактическому содержимому (сигнатуре файла / magic bytes). Исполняемые файлы, скрипты, библиотеки, архивы и иные неутверждённые типы должны блокироваться.	Продемонстрировать отказ для запрещённого файла.
4	Для пользовательского ввода должны применяться меры защиты от prompt injection и jail-break: фильтрация входа, ограничения в системных инструкциях, проверка результата перед выполнением действий.	Продемонстрировать pre-check/post-check в flow. Показать результаты негативных тестов на извлечение системного промпта, обход запретов и навязывание действий.
5	Модель не должна самостоятельно выполнять критичные действия во внешних системах на основании текста пользователя или документа. Действия должны проходить валидацию параметров и, при необходимости, подтверждение пользователя или оператора.	Показать список доступных tools, схему параметров, allow-list операций и этап подтверждения. Продемонстрировать блокировку произвольного SQL, URL, команды ОС или неразрешённой операции.
6	Инструменты, API и коннекторы, доступные flow, должны предоставляться по принципу минимальных привилегий.	Показать сервисные учётные записи, права и перечень доступных tools. Подтвердить отсутствие избыточных, особенно административных, прав.
7	Секреты не должны храниться в системных промптах, тексте flow, коде кастомных компонентов, логах и экспортируемых конфигурациях.	Продемонстрировать интеграцию с Vault, а также передачу секретов в него.
8	Должны быть настроены квоты и gate limiting на обращения к Langflow и моделям.	Продемонстрировать выполненные настройки квот и gate limiting.
9	При использовании RAG документы должны поступать только из доверенных источников. Загрузка, изменение и удаление документов должны быть ограничены и журналируемы.	Показать список источников, владельцев, права на загрузку и журналирование операций. Проверить, что неавторизованный пользователь не может добавить документ в векторную БД.
10	При использовании RAG должна обеспечиваться изоляция данных разных подразделений, систем или пользователей и фильтрация выдачи по правам доступа.	Показать отдельные коллекции. Выполнить запросы под разными ролями и подтвердить отсутствие доступа к чужим документами.
Конфиденциальность		
1	Пользовательский доступ к промышленным (мастер) БД на чтение, изменение, создание таблиц и удаление таблиц должен быть исключен.	1. Продемонстрировать отсутствие прямого доступа к промышленным (мастер) БД.
2	Хранение и использование промышленных конфиденциальных данных (ПДн клиентов, КТ) на тестовых стендах запрещено. При необходимости могут использоваться надлежащим образом обезличенные данные (через сервис sauron)	1. Продемонстрировать отсутствие конфиденциальных данных (ПДн клиентов, КТ) на тестовых стендах.
Аудит событий пользовательских действий		
1	Необходимо логировать все действия администратора, т.е. попытки авторизации, изменения конфигурации, добавление новых пользователей, изменения атрибутов доступа и иные значимые события.	1. Продемонстрировать все события пользовательских действий в сервисе.
2	Должны вестись журналы обращений к модели, вызовов инструментов, ошибок, изменений flow и событий доступа. Журналы не должны содержать секретов и избыточных персональных данных.	
3	Наличие в журнале аудита чувствительных данных (пароли и иные секреты) должно быть исключено. При этом хранение ПДн в журнале аудита допустимо, если это журнал аудита системы, работающей с такими данными. Журнал подсистемы аудита должен вестись таким образом, чтобы исключить возможность его несанкционированной модификации как путем штатных действий в рамках системы, так и извне ее. Срок хранения журнала аудита должен составлять не менее трех лет, но может быть увеличен в зависимости от потребностей бизнес-процесса и законодательства РФ. При необходимости аудит может архивироваться. Факт архивации так же должен фиксироваться в журнале аудита.	
Логирование		
1	В системе реализовано логирование нескольких уровней: DEBUG, INFO, WARNING, ERROR, CRITICAL. В системах должно быть реализовано логирование, уровень логирования не ниже INFO. Уровень логирования выше (детальнее) INFO в пром контуре запрещен. В случае крайней необходимости более детальный уровень логирования на постоянной основе (Debug или trace) может быть согласован экспертами кибербезопасности при условии реализации митигирующих мер: маскирования чувствительных данных в логах (ПДн, секреты, токены и т.д.) и оценки достаточности логирования на уровне INFO. Временное (1-2 дня) включение более детального уровня логирования на проде для целей решения тикетов допустимо. Под логированием уровня INFO подразумевается: а. Отсутствие индикаторов отладки или внутренней логики б. Указание ключевого высокоуровневого функционала сервиса в. Понятность и полезность эксплуатации сообщений для целевых потребителей (без технического углубления) г. Отсутствие генерации большого объема записей на один процесс Хранение ПДн или любой другой клиентской информации в логах запрещено. При необходимости логирования запросов полностью все конфиденциальные данные должны быть замаскированы (заменены на *, любые другие константные значения или обрезаны). Целевое решение: стандартизировать логи в Opensearch согласно Архкому Пример событий, подлежащих логированию: а. ошибки установления соединения; б. факт обработки сообщения; в. результат обработки сообщения	1. Продемонстрировать логи сервиса в Opensearch.
Обработка ошибок		
1	Сообщения об ошибках, отображаемые и доступные в публичной части веб-приложения и мобильном приложении, должны носить общий характер и не должны раскрывать технические	При наличии фронта*

таблица 1. Требования

№	Требования КБ	Методы проверки
	детали и внутреннюю логику работы системы. Необходимо контролировать statusCode и message в заголовках, отправляемых сервером при возникновении ошибок. В случае ошибки, необходимо передавать общий код ошибки и сообщение, по которым невозможно уменьшить пространство перебора.	1. Продемонстрировать сообщения об ошибках, отображаемые и доступные в публичной части веб-приложения и мобильном приложении.
Пентест		
1	Перед вводом в промышленную эксплуатацию система должна пройти тестирование на наличие уязвимостей (pentest), осуществляемое в соответствии с внутренним регламентом Домклик. Обязательному тестированию подлежат все сервисы, выводимые в промышленную эксплуатацию.	1. Предоставить задачи Jira с заключением о пройденном пентесте.

Нет меток